

VORON CITADEL

Proof of Concept Plan

Prepared for Bursa Malaysia

Four-week controlled evaluation with measurable technical and business decision criteria

Document	Value
Document status	Customer-facing working draft - not a contract
Version	0.1
Date	20 August 2026
Prepared for	Bursa Malaysia
Prepared by	Voron Citadel / VoronDRQ Commercial & Solutions Engineering
Classification	Confidential - for evaluation and discussion only

Naming note	This document uses “Voron Citadel” as the POC/customer engagement name. Capability statements are anchored to the current VoronDRQ sales kit and product brochure supplied through the project repository.
-------------	--

Document Control

Field	Details
Purpose	Define the objectives, scope, technical design, execution model, test cases, success criteria, governance and decision process for a controlled Voron Citadel POC at Bursa Malaysia.
POC duration	4 weeks from environment provisioning, followed by up to 1 week for final reporting.
Primary audience	Executive sponsor, Risk & Compliance, Cybersecurity, Technology, Enterprise Architecture, GRC, Procurement/Legal, and POC evaluators.
Commercial status	Technical/evaluation plan. Fees, licensing, contractual terms, data-processing terms and production commitments are governed separately.
Change control	Any change to scope, data, integrations, test criteria or timeline must be documented in the POC decision log and approved by both POC leads.

Revision History

Version	Date	Owner	Change
0.1	20 Aug 2026	Voron Citadel	Initial Bursa Malaysia POC working draft

Approval / Acknowledgement

Role	Organisation	Name	Status / Date
Executive Sponsor	Bursa Malaysia	TBD	TBD
POC Lead	Bursa Malaysia	TBD	TBD
Solutions Engineering Lead	Voron Citadel	TBD	TBD
Commercial Lead	Voron Citadel	TBD	TBD

Important	Bursa-specific internal architecture, control gaps, regulatory applicability, systems, asset counts, vendor counts and current operating metrics are intentionally not assumed. They are to be validated during POC kickoff and discovery.
------------------	--

Contents

Section	Title
1	Executive Summary
2	Bursa Malaysia Context and POC Rationale
3	POC Objectives and Decision Questions
4	Guiding Principles
5	Scope and Boundaries
6	Use-Case Catalogue
7	Proposed POC Architecture
8	Data, Integration and Environment Design
9	Security, Privacy and Data Handling
10	POC Test Strategy
11	Detailed Test Scenarios
12	Success Criteria and Scoring Model
13	Implementation Plan and Timeline
14	Roles, Responsibilities and RACI
15	Governance and Working Cadence
16	Issue, Defect and Change Management
17	Risks, Assumptions and Dependencies
18	Exit Criteria and Decision Gates
19	POC Final Report Structure
20	Appendices and References

1. Executive Summary

This Proof of Concept (POC) is designed to give Bursa Malaysia a controlled, evidence-based way to determine whether Voron Citadel can materially improve risk visibility, compliance operations and cross-domain cyber-risk correlation without requiring a production deployment or broad integration commitment.

The POC is deliberately decision-focused. It is not intended to demonstrate every platform feature. Instead, it concentrates on a small number of representative workflows that can be completed within four weeks and measured against jointly agreed pass/fail or scored outcomes.

1.1 Proposed Evaluation Themes

- Unified governance, risk and compliance: demonstrate how a common control and risk model can support multiple Bursa-selected frameworks, policies and evidence requirements.
- External exposure and attack surface: demonstrate authorised discovery, prioritisation and correlation of internet-facing assets and findings into governance/risk workflows.
- Third-party risk: demonstrate risk-tiered vendor assessment, findings, remediation tracking and linkage into the enterprise risk view.
- Digital risk and threat context: demonstrate how approved brand/domain exposure or sample threat events can be correlated with assets, vendors, controls and risks.
- AI-assisted analysis and executive reporting: demonstrate natural-language cross-domain questions, evidence traceability, dashboards and decision-ready outputs.

1.2 Target Decision at POC Close

At the end of the evaluation, Bursa Malaysia should have sufficient evidence to select one of four outcomes: proceed to production solution design; proceed subject to defined remediation/conditions; extend only for specific unresolved criteria; or stop the evaluation. The final recommendation will be supported by a scored success matrix, issue register, evaluator feedback, data-quality findings and an agreed production-readiness gap list.

Dimension	What Bursa should know by the end of the POC
Functional fit	Can the platform execute the selected risk, compliance, ASM, TPRM and digital-risk workflows with acceptable usability and traceability?
Technical fit	Can the proposed deployment, access, data and integration patterns work within Bursa architecture and security constraints?
Operational fit	Can Bursa teams operate the workflows without excessive manual correlation or administration?
Security fit	Does the POC demonstrate required access control, logging, data handling and evidence integrity characteristics?
Value case	Is there a credible path to better risk visibility, faster evidence/reporting workflows and platform consolidation or workflow simplification?

2. Bursa Malaysia Context and POC Rationale

Bursa Malaysia's public Risk & Compliance materials describe an enterprise risk management approach supported by technology and cybersecurity risk management, business continuity, outsourcing-risk controls and procedures aligned to industry standards, best practices and regulatory requirements. This makes a cross-domain risk and evidence platform a relevant evaluation area, while the POC must remain grounded in Bursa-selected internal requirements rather than assumptions.

Bursa's public BTS3 transformation guidance also highlights stakeholder readiness, performance and reliability testing, early resource planning, and controlled change as practical implementation risk themes. The POC adopts the same discipline: define success before execution, minimise unnecessary system change, test explicitly, and maintain clear owners and decision gates.

POC framing	The statements above provide public context only. They do not represent a claim that Bursa has a particular control deficiency, technology gap, incident history or procurement intent.
--------------------	---

2.1 Why a POC Instead of a Feature Demo

- A feature demo proves that functionality exists; a POC tests whether selected functionality works against Bursa-defined data, roles, evidence and operating constraints.
- A POC creates a reproducible evidence pack: input data, execution steps, observed result, defect/limitation, evaluator acceptance and business implication.
- A limited evaluation reduces integration and data-handling risk while allowing architecture, security and operational questions to be answered early.
- Measurable success criteria provide a clean transition from technical evaluation to a production design or procurement decision.

2.2 Hypotheses to Validate

ID	Hypothesis
H1	A unified data model can reduce manual cross-referencing between assets, vendors, controls, risks and findings.
H2	Bursa-selected control/evidence workflows can be represented without excessive customisation.
H3	External exposure findings can be prioritised using business context rather than treated as an isolated scanner output.
H4	Third-party observations can feed an enterprise risk view with traceable ownership and remediation actions.
H5	AI-assisted queries can return useful cross-domain answers with evidence/citations sufficient for analyst review.
H6	Executive dashboards can summarise posture while retaining drill-down to the underlying evidence and records.

3. POC Objectives and Decision Questions

ID	Objective	POC outcome
O1	Validate core workflow fit	Prove selected end-to-end workflows using representative Bursa-approved data and users.
O2	Validate cross-domain correlation	Show traceable relationships across assets, controls, findings, risks, vendors and evidence.
O3	Validate architecture and security	Confirm an acceptable POC access, data, logging and integration pattern.
O4	Measure operational usability	Assess analyst/admin effort, workflow clarity, evidence retrieval and reporting experience.
O5	Identify production gaps	Produce a prioritised list of configuration, integration, data, security and operating-model actions required for production.
O6	Support an investment decision	Provide a scored, jointly signed POC outcome rather than a qualitative demo conclusion.

3.1 Decision Questions

- Can Bursa represent its selected risk/control structure and evidence requirements in Citadel with acceptable configuration effort?
- Can the platform show a single traceable relationship from external or third-party finding to asset/vendor, risk, control, owner and remediation action?
- Can users retrieve evidence and generate decision-ready reports within the agreed benchmark?
- Can the POC meet Bursa security and data-handling expectations for an evaluation environment?
- Which production integrations are essential, optional or unnecessary?
- What data-quality, operating-model or ownership changes would be required to realise value at scale?
- Does the result justify moving to production solution design and commercial negotiation?

4. Guiding Principles

Principle	Application
Decision before demonstration	Every POC activity must map to a decision question or success criterion.
Minimum necessary scope	Use the smallest data set and integration surface that can prove the intended outcome.
No unapproved intrusive activity	No scanning, probing, credentialed testing or production write action without explicit written authorisation and agreed target scope.
Read-only by default	External system connectivity is read-only unless a specific write-back test is separately approved.
Synthetic data where practical	Use synthetic, redacted or representative data unless real data is necessary for a criterion.
Evidence over opinion	A criterion is accepted based on recorded test evidence and evaluator sign-off.
Security by design	Least privilege, named accounts, audit logging, approved retention and controlled export apply throughout the POC.
No hidden production commitment	POC success does not itself authorise production rollout, procurement or unrestricted data processing.

5. Scope and Boundaries

5.1 In Scope

- One isolated Voron Citadel POC tenant/environment.
- Up to 20 named Bursa evaluators unless changed by mutual agreement.
- Representative samples of controls, risks, evidence, internet-facing assets, vendors and findings, sized to prove functionality rather than test enterprise-scale migration.
- Configuration of Bursa-selected workflows and dashboards required for the approved use cases.
- File-based ingestion (CSV/JSON) and, where justified, one or two read-only connector/API demonstrations.
- Role-based access, audit logging, data export, reporting and evidence traceability tests.
- Weekly governance checkpoints and a final success review.
- Final POC report with findings, scorecard, unresolved gaps and production recommendation.

5.2 Explicitly Out of Scope Unless Added by Change Control

- Production deployment, cutover, high availability or production disaster-recovery certification.
- Full migration of Bursa production data, historical evidence repositories or complete vendor inventories.
- Unrestricted or intrusive vulnerability scanning of Bursa assets.
- Automated remediation or write-back into production ticketing, SIEM, CMDB, identity or security tooling.
- Penetration testing of Voron Citadel or Bursa systems beyond agreed security assurance artefacts and POC validation checks.
- Formal regulatory certification, legal opinion, audit attestation or representation that a framework is fully satisfied merely because a control is mapped in the platform.
- Production performance, capacity or SLA commitments beyond POC benchmarks.
- Commercial negotiation, licensing or contractual commitments.

5.3 Suggested POC Data Envelope

Data type	Suggested POC range	Notes
Controls / requirements	30-60	Representative subset selected by Bursa; include evidence metadata.
Risks	10-25	Include owners, ratings, treatment status and linked controls where available.
Assets / domains	25-75	Only Bursa-authorized targets or representative/synthetic records.
Findings	20-50	Mix of sample and authorised external observations.
Vendors	5-10	Representative tiers and risk profiles; synthetic vendors acceptable.
Evidence items	20-50	Documents/links/metadata sufficient to test traceability and retrieval.
Users	Up to 20	Admin, analyst, reviewer, approver and read-only personas.

6. Use-Case Catalogue

ID	Use case	Priority	Primary owner	POC demonstration
UC-01	Unified GRC and multi-framework evidence	Primary	Risk/GRC	Create a common control set, map selected requirements, attach evidence, record effectiveness and show one-to-many framework relationships.

ID	Use case	Priority	Primary owner	POC demonstration
UC-02	Authorised attack-surface visibility	Primary	Cybersecurity / ASM	Discover or ingest authorised external assets and findings, validate ownership, prioritise exposure and link material findings into risk/control workflows.
UC-03	Third-party risk lifecycle	Primary	TPRM / Risk	Onboard representative vendors, apply tiering/questionnaires, record findings, assign actions and show vendor-risk contribution to enterprise posture.
UC-04	Digital-risk / threat correlation	Primary	Cybersecurity / DRM	Ingest approved brand/domain threat examples or sample events and correlate them with relevant assets, vendors, risks and actions.
UC-05	AI Analyst Copilot	Cross-cutting	All evaluators	Ask approved natural-language cross-domain questions and verify that answers are evidence-linked, reviewable and do not replace human approval.
UC-06	Executive dashboard and evidence report	Cross-cutting	Management	Produce a consolidated risk/compliance view with drill-down and exportable evidence for management review.
UC-07	Read-only integration pattern	Optional	IT / Architecture	Demonstrate one approved connector or API ingestion pattern to validate authentication, field mapping, logging and failure handling.

6.1 UC-01 - Unified GRC and Multi-Framework Evidence

Bursa selects a representative control domain and one or more applicable internal/external requirement sets. The POC configures a control hierarchy, ownership, status/effectiveness, evidence metadata, test result and risk linkage. The core question is whether a single control record can support multiple obligations and provide a clean audit trail without duplicating evidence.

Input	Action	Expected evidence
Selected requirements and controls	Import/configure control records and map relationships	Mapping table with owner, requirement, control, evidence and status.
Evidence samples	Attach or reference evidence and record validation status	Evidence provenance, timestamp, reviewer and link to control.
Control test result	Record design/operating effectiveness or equivalent Bursa rating	Control result flows into risk/compliance dashboard.
Management query	Filter by framework, owner, status, evidence age or risk	Exportable, traceable result set.

6.2 UC-02 - Authorised Attack-Surface Visibility

The POC uses an explicitly authorised domain/asset set or supplied sample records. The purpose is not to conduct a broad security assessment; it is to validate asset discovery/ingestion, ownership, prioritisation, workflow and correlation into the enterprise risk/control view.

6.3 UC-03 - Third-Party Risk Lifecycle

The POC represents a small vendor sample across at least two risk tiers. Evaluators test onboarding, assessment assignment, finding creation, remediation ownership, due dates and executive visibility. Where external monitoring is enabled, observations must be traceable to the selected vendor and handled as evidence requiring analyst review.

6.4 UC-04 - Digital-Risk / Threat Correlation

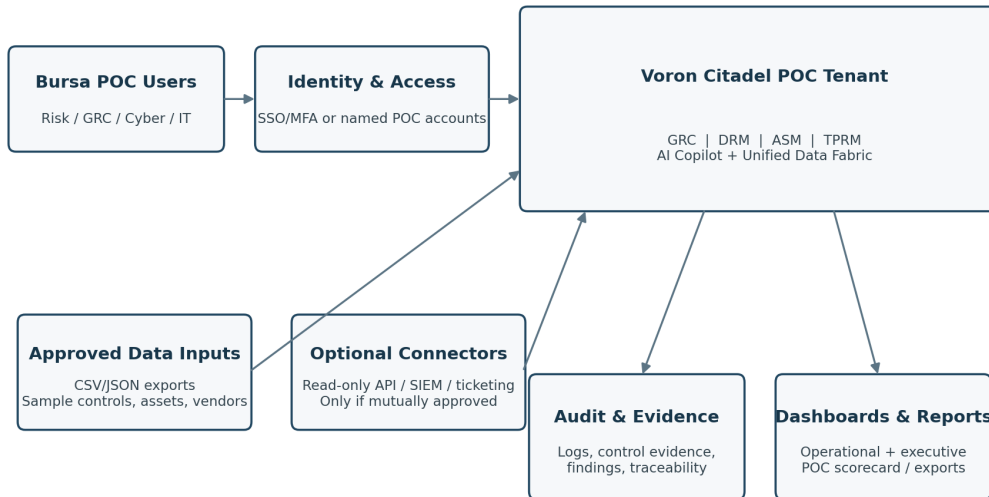
Bursa and Voron agree an approved set of sample events, such as look-alike domains, phishing indicators, exposed credentials in synthetic form, or brand-abuse examples. The test focuses on triage, relevance, ownership, linkage to assets/vendors and escalation to risk/action records.

6.5 UC-05 / UC-06 - Copilot and Executive Reporting

AI and dashboards are treated as cross-cutting capabilities. Copilot responses must be reviewable and evidence-linked; an answer without supporting records is not considered a successful result. Executive views must permit drill-down to the underlying evidence and make clear which values are observed, calculated or manually entered.

7. Proposed POC Architecture

The baseline design is an isolated evaluation tenant with named-user access, controlled data ingestion and optional read-only connectivity. This minimises the blast radius of the evaluation while still allowing Bursa to test end-to-end data and workflow behaviour.



POC security principle: isolated evaluation environment, least privilege, approved data only, and no intrusive production activity without written authorisation.

Figure 1. Conceptual POC architecture (to be confirmed during technical kickoff).

7.1 Logical Components

Component	POC design
User access	Browser-based access using named POC accounts. SSO/MFA demonstration may be included if Bursa and Voron can complete prerequisites within the POC window.
Citadel services	GRC, DRM, ASM and TPRM domain services operating on a shared data model / data fabric, with AI Copilot and reporting.
Data ingestion	CSV/JSON import as the default. Approved REST/API or connector patterns are optional and read-only by default.
Evidence and audit	Audit records, test evidence, control evidence, findings and exports maintained for POC validation.
Administration	Configuration of roles, workflow states, owners, taxonomies, fields and dashboards necessary for the approved use cases.

7.2 Architecture Decision Records (ADRs) to Resolve During Kickoff

- Hosting/deployment mode for the POC tenant and any Bursa data-residency constraints.
- Identity approach: local named accounts versus SSO demonstration.
- Whether any connector/API is necessary to prove the use cases or file import is sufficient.
- Data classification permitted in the POC and required masking/redaction.
- Whether ASM/DRM uses live authorised data, supplied evidence or synthetic scenarios.
- POC retention period and deletion/return process at conclusion.

8. Data, Integration and Environment Design

8.1 Data Onboarding Approach

The POC should prioritise representative data quality over data volume. Bursa nominates data owners and provides only the fields needed to prove each criterion. Voron supplies mapping templates before kickoff and performs a dry-run validation before import.

Step	Owner	Output / acceptance
Define dataset and classification	Bursa	Approved data inventory with owner and classification.
Prepare mapping template	Voron	Field-level import template and required/optional fields.
Redact / synthesise where needed	Bursa	Dataset cleared for POC use.
Dry-run validation	Voron	Data-quality report: completeness, duplicates, invalid values, unmapped fields.
Import / configuration	Voron	Loaded records reconciled to source counts.
Business validation	Bursa	Sample records confirmed accurate and usable.

8.2 Integration Strategy

Integration is not a goal by itself. A connector is included only when it answers a material decision question. The default POC uses controlled file import because it is fast, auditable and does not create unnecessary dependency on production firewall, service-account or change-management processes.

Pattern	POC position	Controls
CSV/JSON import	Default	Checksum/version data file, owner approval, reconciliation after load.
REST API ingestion	Optional	Read-only token, minimum scopes, allowlisted endpoint, request/response logging.
SIEM / ticketing connector	Optional	Read-only demonstration unless a separate write test is explicitly approved.
SSO	Optional	Use test/non-production app registration and least-privilege group mapping.
Outbound export	In scope	Restrict to approved evaluators; log export event; avoid sensitive data in unmanaged destinations.

8.3 Environment Prerequisites

- Named Bursa POC lead and technical contact.
- Approved user list and roles.
- Approved data set and data-classification decision.
- Approved test asset/domain list if live ASM is enabled.
- Network/firewall or SSO prerequisites only for agreed optional integrations.

- Browser access to the POC environment.
- Secure channel for transfer of POC data and evidence.
- Agreed communication/escalation channel for defects and urgent security issues.

9. Security, Privacy and Data Handling

POC security must be treated as part of the evaluation, not an administrative afterthought. The objective is to demonstrate a defensible evaluation environment while avoiding unnecessary exposure of Bursa production data or systems.

Control area	POC requirement
Identity	Named users; least privilege; admin accounts separated from ordinary evaluator accounts; MFA/SSO where feasible.
Access review	User list reviewed at kickoff and POC close; dormant/unneeded accounts removed promptly.
Data minimisation	Only data necessary for the selected criteria is loaded; sensitive values redacted or synthesised when possible.
Encryption	Use platform-standard encryption for data in transit and at rest as stated in the current product baseline; exact POC implementation to be confirmed in security review.
Audit logging	Record administrative changes, authentication events and relevant user actions required to reconstruct POC tests.
Exports	Controlled and logged; no bulk export to unmanaged destinations.
Scanning	No unapproved intrusive scanning; scope list and rate/technique restrictions documented before any live external activity.
Retention	POC data retained only for the agreed evaluation/reporting period, then returned/deleted according to the executed agreement and Bursa requirements.
Incident handling	Suspected security events affecting the POC environment escalated immediately through agreed contacts; POC activity may be suspended if containment is required.

9.1 Data Classification Worksheet

Dataset	Owner	Classification	Real / synthetic	Permitted fields	Retention
Controls / requirements	TBD	TBD	TBD	TBD	TBD
Risk register sample	TBD	TBD	TBD	TBD	TBD
Asset/domain list	TBD	TBD	TBD	TBD	TBD
Vendor sample	TBD	TBD	TBD	TBD	TBD
Evidence documents	TBD	TBD	TBD	TBD	TBD

Security gate	No Bursa dataset is loaded until its owner, classification, permitted fields and retention decision are recorded.
----------------------	---

10. POC Test Strategy

The POC uses scenario-based validation. Every test has a unique ID, preconditions, steps, expected result, evidence requirement, severity if failed, and Bursa evaluator acceptance. Demonstration alone is insufficient; the result must be reproducible or evidenced.

10.1 Test Categories

Category	Purpose	Examples
Functional	Validate business workflow	Control mapping, vendor assessment, finding-to-risk linkage.
Integration	Validate approved data movement	File import, API ingestion, field mapping, error handling.
Security	Validate evaluation controls	RBAC, audit log, user access, export control.
Usability	Assess evaluator effort	Time to find evidence, create a risk, assign action, build report.
Traceability	Prove provenance and linkage	Finding -> asset/vendor -> risk -> control -> owner -> evidence.
Reporting	Validate management output	Dashboard, filter, drill-down, export, evidence pack.
Resilience / failure handling	Validate safe failure	Invalid input, duplicate records, unavailable connector, permission denial.

10.2 Test Evidence Standard

- Test ID and date/time.
- Tester/evaluator.
- Input record(s) or scenario reference.
- Step-by-step action or demonstration recording reference.
- Observed result and screenshot/export/log reference where appropriate.
- Defect/limitation ID if result differs from expected.
- Bursa acceptance: Pass, Pass with Condition, Fail, or Not Run.
- Comment and sign-off/acknowledgement.

10.3 Severity Definitions

Severity	Definition	POC impact
S1 - Critical	Security, data integrity or core workflow issue prevents safe continuation.	Stop affected test; immediate escalation; may trigger POC pause.
S2 - High	Primary success criterion cannot be met and no acceptable workaround exists.	Must be resolved or explicitly accepted before successful POC decision.
S3 - Medium	Material limitation with workaround or configuration change.	Track as condition / production gap.
S4 - Low	Cosmetic, usability or minor documentation issue.	Track; does not normally block POC success.

11. Detailed Test Scenarios

Test ID	Scenario	UC	Precondition	Expected result	Evidence	Priority
GRC-01	Import selected control set	UC-01	Control template approved	All required control fields import successfully; rejected rows are identified with actionable error detail.	Import report + record count	Must

Test ID	Scenario	UC	Precondition	Expected result	Evidence	Priority
GRC-02	Map one control to multiple requirement sets	UC-01	At least two Bursa-selected requirement sets	Single control is linked to multiple requirements without duplicating evidence.	Mapping export / screen evidence	Must
GRC-03	Attach and retrieve evidence	UC-01	Evidence sample available	Evaluator retrieves evidence and sees owner/status/date/provenance from the control record.	Evidence record + audit trail	Must
GRC-04	Control result changes risk/compliance view	UC-01	Control test states configured	Changing approved test result is reflected in relevant dashboard/risk view with traceability.	Before/after evidence	Should
ASM-01	Authorised asset discovery or import	UC-02	Approved target list	Platform identifies/imports assets and records source, ownership status and timestamps.	Asset inventory	Must
ASM-02	Finding prioritisation	UC-02	Representative findings	Evaluator can prioritise based on severity plus business context/ownership.	Prioritised finding list	Must
ASM-03	Finding-to-risk linkage	UC-02	Material finding selected	Finding is linked to an enterprise risk/control/action with owner and due date.	Relationship trail	Must
ASM-04	Unknown asset workflow	UC-02	One unowned sample asset	Asset can be flagged, assigned for validation and resolved without losing original evidence.	Workflow history	Should
TPRM-01	Vendor onboarding and tiering	UC-03	5-10 vendor samples	Vendor is onboarded, tiered and assigned an assessment based on defined criteria.	Vendor record + tier rationale	Must
TPRM-02	Assessment finding and remediation	UC-03	Questionnaire response sample	Material answer creates finding/action with owner, priority and due date.	Finding/action trail	Must
TPRM-03	Vendor risk to enterprise view	UC-03	At least one high-risk vendor	Vendor issue is visible in consolidated risk reporting with drill-down.	Dashboard + linkage	Must
DRM-01	Digital-risk event triage	UC-04	Approved sample event	Event is classified, assigned and linked to relevant asset/vendor/risk as applicable.	Triage record	Should
AI-01	Cross-domain query with evidence	UC-05	Sufficient linked records	Copilot answers a pre-agreed question and provides evidence-linked records sufficient for analyst verification.	Query transcript + cited records	Must
AI-02	Unsupported/ambiguous query behaviour	UC-05	Ambiguous test prompt	System indicates uncertainty/limits or requires refinement; evaluator is not presented with unsupported certainty.	Query transcript	Should
RPT-01	Executive dashboard drill-down	UC-06	Dataset populated	Management view summarises selected metrics and allows drill-down to source records.	Dashboard capture/export	Must
RPT-02	Evidence/report export	UC-06	Report definition agreed	Evaluator generates an export containing agreed fields within target time and with traceability.	Export file + timing	Must
SEC-01	Role-based access	Cross-cutting	At least 3 personas	Users can access authorised functions while restricted functions are denied.	Access matrix + test evidence	Must
SEC-02	Audit trail	Cross-cutting	Auditable actions performed	Evaluator can identify who performed selected changes and when.	Audit-log extract	Must
INT-01	Import error handling	UC-07	Invalid/duplicate rows	System identifies errors without corrupting accepted records; re-import path is clear.	Error report + reconciliation	Should
INT-02	Optional read-only API/connector	UC-07	Approved connector available	Authentication, mapping and ingestion complete without production write action.	Connector log + sample records	Optional

11.1 Acceptance Recording Template

Test ID	Result	Evaluator	Evidence ref	Defect / condition	Comment
—	Pass / Conditional / Fail / Not Run	—	—	—	—
—	Pass / Conditional / Fail / Not Run	—	—	—	—
—	Pass / Conditional / Fail / Not Run	—	—	—	—

12. Success Criteria and Scoring Model

The final decision should not be based on a single headline percentage. “Must” criteria act as gates; weighted scoring provides additional differentiation among acceptable outcomes. Bursa and Voron should freeze the scorecard at the end of Week 1, before substantive testing begins.

ID	Criterion	Weight	Gate	Acceptance statement
SC-01	GRC representation & traceability	15	Must	Selected controls, requirements and evidence can be represented and traced without unacceptable duplication.
SC-02	Cross-domain risk linkage	15	Must	At least three representative findings/events can be traced to relevant asset/vendor, risk, control, owner and action as applicable.
SC-03	Evidence retrieval & reporting	10	Must	Agreed evidence/report output can be produced within the benchmark agreed in Week 1 and retains source traceability.
SC-04	Attack-surface workflow	10	Must	Authorised asset/finding workflow supports ownership validation, prioritisation and risk/action escalation.
SC-05	Third-party risk workflow	10	Must	Representative vendors can be tiered, assessed and linked to findings/actions and consolidated risk views.
SC-06	Access control & auditability	10	Must	Role restrictions and audit trail pass agreed security tests.
SC-07	AI analyst usefulness	10	Should	Pre-agreed cross-domain questions are answered with evidence sufficient for analyst verification; unsupported certainty is not accepted.
SC-08	Evaluator usability	10	Should	Bursa evaluators rate core workflows acceptable against agreed usability questions and no S2 usability blocker remains.
SC-09	Data & integration feasibility	5	Should	Required POC data loads cleanly and essential production integration pattern(s) are judged feasible.
SC-10	Production gap clarity	5	Must	Final report identifies material production actions, owners, dependencies and unresolved risks.

12.1 Rating Scale

Score	Definition
5 - Exceeds	Criterion met with strong evidence; no material gap and outcome is easier/faster than expected.
4 - Meets	Criterion met with acceptable evidence; minor limitations do not affect intended outcome.
3 - Meets with condition	Outcome is achievable but requires a known configuration, process or integration condition.
2 - Partially meets	Material gap remains; workaround is significant or evidence is incomplete.
1 - Does not meet	Criterion not demonstrated or outcome is unacceptable.
0 - Not tested	No evidence; cannot be counted as successful.

12.2 Recommended Decision Thresholds

Decision	Recommended rule
Proceed to production design	All “Must” gates score ≥ 3 , no unresolved S1/S2 defect, and weighted overall score $\geq 80\%$.

Decision	Recommended rule
Proceed with conditions	All critical security/data gates pass; one or more functional Must criteria score 3 with documented remediation; overall $\geq 70\%$.
Targeted extension	A small number of material criteria remain untested due to external dependency, and a time-boxed extension is expected to resolve them.
Stop / re-evaluate	Any unresolved S1 issue; material security/data concern; multiple Must criteria < 3 ; or overall evidence does not support a credible production path.
Final authority	Bursa Malaysia retains decision authority. Thresholds above are proposed evaluation rules and should be confirmed by Bursa at the Week 1 success-criteria workshop.

13. Implementation Plan and Timeline

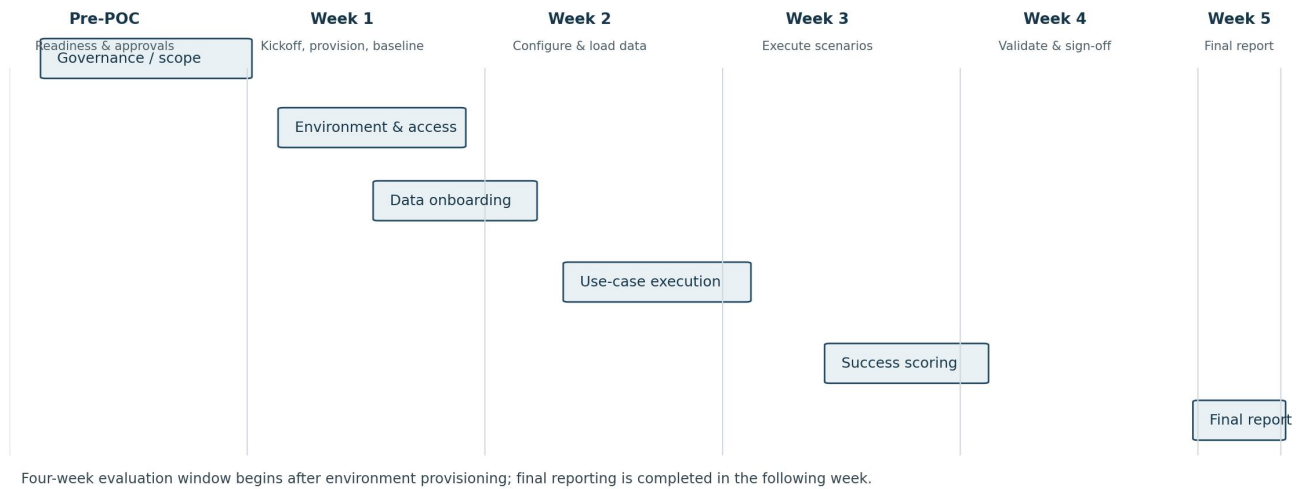


Figure 2. Proposed POC execution timeline.

13.1 Pre-POC Readiness (before the four-week clock)

ID	Activity	Owner	Exit condition
P0.1	POC agreement / NDA / data-handling terms ready	Both	No data transfer before required agreements.
P0.2	Bursa nominates sponsor, lead and evaluators	Bursa	Names, roles and contact/escalation list.
P0.3	Use cases and target data agreed	Both	Scope baseline and data inventory.
P0.4	Authorised ASM/DRM target scope approved, if applicable	Bursa	Written authorised target list / technique constraints.
P0.5	Environment prerequisites validated	Voron	Provisioning checklist passed.

13.2 Week 1 - Kickoff, Provisioning and Baseline

- Kickoff: confirm objectives, governance, scope boundaries and escalation path.
- Provision users and roles; verify access and logging.
- Conduct data mapping and security/data-classification review.
- Freeze test cases, benchmarks and success criteria.
- Load initial data and validate sample records.
- Baseline current process timings/effort only where Bursa wishes to compare value.

13.3 Week 2 - Configuration and Data Onboarding

- Configure GRC structures, selected workflows, taxonomies, vendor tiers and dashboards.
- Load approved asset/vendor/finding/evidence samples.
- Configure optional read-only connector only if essential.
- Execute dry-run tests and fix data/configuration issues before formal evaluation.
- Train Bursa evaluators on the exact workflows they will test.

13.4 Week 3 - Scenario Execution

- Run formal functional, traceability, AI, reporting, access-control and integration tests.
- Log defects and limitations with severity and owner.
- Hold mid-POC checkpoint focused on failed Must criteria and dependencies.
- Avoid scope expansion; use change control for any new scenario.

13.5 Week 4 - Validation and Decision Readiness

- Re-test resolved defects and conditional criteria.
- Complete evaluator scoring and usability feedback.
- Validate exports, audit trail and data-retention/deletion plan.
- Run executive demonstration using only scenarios that have passed formal tests.
- Conduct success-scorecard workshop and record preliminary decision.

13.6 Week 5 - Final Report

- Issue final POC report within five business days of POC conclusion.
- Include usage/test statistics, success matrix, defects/conditions, evaluator feedback, architecture findings and production recommendations.
- Document data return/deletion and account closure actions.
- If proceeding, initiate production discovery/SOW as a separate authorised phase.

14. Roles, Responsibilities and RACI

Role	Core responsibility
Executive Sponsor - Bursa	Business sponsorship, escalation and final decision authority.
POC Lead - Bursa	Day-to-day coordination, scope decisions, evaluator availability, success-scorecard ownership.
Risk/GRC SME - Bursa	Control/risk use cases, framework selection, evidence validation.
Cybersecurity SME - Bursa	ASM/DRM scope, technical findings validation, scanning authorisation.
IT / Enterprise Architecture - Bursa	Access, integration, identity, network and architecture review.
Data Owners - Bursa	Approve datasets, classification and permitted use.
POC PM - Voron	Plan, governance, issue tracking, reporting and coordination.
Solutions Engineer - Voron	Environment configuration, data load, integrations, training and test support.
Product / Engineering - Voron	Defect triage, product clarification and remediation where required.
Commercial / Legal - Both	Separate contractual/commercial terms; not responsible for technical acceptance unless specifically assigned.

14.1 RACI Matrix

Activity	Bursa POC Lead	Bursa GRC	Bursa Cyber	Bursa IT/EA	Voron POC Team
Approve scope / success criteria	A/R	C	C	C	R
Approve POC datasets	A/R	C	C	C	C
Provision POC tenant	I	I	C	I	A/R
Configure workflows	C	A/R	C	I	R
Authorise live ASM scope	A	I	R	C	C
Execute formal tests	A/R	R	R	C	R
Log / triage defects	C	C	C	I	A/R
Accept test evidence	A/R	R	R	C	C
Final success score	A/R	C	C	C	C
Final POC report	C	C	C	C	A/R

R = Responsible; A = Accountable; C = Consulted; I = Informed.

15. Governance and Working Cadence

Meeting / artefact	Frequency	Participants	Purpose
POC kickoff	Once	Sponsor/POC leads/SMEs	Confirm scope, rules, timeline, success criteria and escalation.
Working stand-up	2-3x weekly or as agreed	POC leads + active SMEs	Remove blockers, coordinate tests and data/configuration changes.
Weekly steering checkpoint	Weekly	POC leads + sponsor delegate	Review scorecard, S1/S2 issues, decisions, scope and next-week plan.
Defect triage	As required	Technical leads	Assign severity, owner, workaround and retest date.
Decision log	Continuous	POC leads	Record decisions that affect scope, data, integration, success criteria or risk.
Final success workshop	End Week 4	Decision stakeholders	Validate evidence, score criteria and record preliminary outcome.
Final report review	Week 5	Sponsor/POC leads	Approve POC conclusion and next-step recommendation.

15.1 Minimum POC Artefacts

- Approved scope baseline and authorised target list (if live external testing).
- Data inventory/classification sheet.
- User/role access list.
- Test-case register and evidence references.
- Defect/issue register.
- Decision/change log.
- Success-scorecard workbook/table.
- POC final report and data-closeout confirmation.

16. Issue, Defect and Change Management

16.1 Defect Workflow

1. Record issue with test ID, evidence, severity, business impact and reproducibility.
2. Joint technical triage determines defect vs configuration vs data-quality vs expected behaviour.
3. Assign owner and target retest date.
4. Where workaround exists, record the operational cost/limitation; do not silently mark as pass.
5. Retest using the original scenario and evidence standard.
6. Close only after Bursa evaluator confirms result or explicitly accepts a condition.

16.2 Change Control

Any material addition of modules, datasets, live targets, integration endpoints, user groups, success criteria or test duration requires an explicit change record. The change should state the rationale, schedule impact, security/data impact, owner and whether the original decision timeline changes.

Change ID	Requested change	Reason	Impact	Decision	Owner
CR-___	TBD	TBD	Scope / time / security / data	Approve / reject / defer	TBD
CR-___	TBD	TBD	Scope / time / security / data	Approve / reject / defer	TBD

17. Risks, Assumptions and Dependencies

ID	Risk	Impact	Trigger / concern	Mitigation	Owner
R1	Late data approval	High	Data owners unavailable or classification unclear delays Week 1/2.	Agree dataset owners before kickoff; use synthetic data fallback.	Bursa POC Lead
R2	Scope expansion	High	New use cases consume limited four-week window.	Freeze scope end Week 1; require change control.	Both POC Leads
R3	Live ASM authorisation ambiguity	High	Testing could exceed approved boundaries.	Written asset/domain scope and technique constraints before activation.	Bursa Cyber
R4	Integration dependency	Medium	Firewall/service-account/API work consumes POC schedule.	File import by default; include connector only if decision-critical.	Bursa IT / Voron SE
R5	Data quality	Medium	Duplicate/incomplete records distort results.	Pre-load profiling and reconciliation; score data-quality separately from product fit.	Data Owner / Voron SE
R6	Evaluator availability	Medium	Insufficient hands-on validation leads to weak evidence.	Book evaluation windows and backups before kickoff.	Bursa POC Lead
R7	AI over-reliance	Medium	Users treat generated output as authoritative without evidence review.	Require evidence-linked responses and human validation; AI does not approve risk decisions.	Both
R8	POC-to-production assumption	Medium	POC configuration is mistaken for production architecture.	Document production gaps and conduct separate production design.	Both
R9	Sensitive data exposure	High	Unnecessary real data enters evaluation environment.	Data minimisation/redaction; owner approval; controlled export and retention.	Bursa Data Owner
R10	Unresolved S2 defect	High	Core criterion remains materially impaired at close.	Escalate early; targeted remediation/retest or conditional/failed criterion.	Voron POC Lead

17.1 Key Assumptions

- Bursa will provide timely access to agreed evaluators and data owners.
- The POC environment is for evaluation only and is not used to operate production risk processes.
- Any framework mapping demonstrated is subject to Bursa validation of applicability and content.
- Bursa will determine which data can be used and whether synthetic/redacted data is required.
- Voron will provide dedicated solutions-engineering support during the agreed working window.
- Material product limitations identified in the POC are recorded transparently rather than worked around without disclosure.

17.2 Dependencies

- Executed legal/confidentiality/data-processing documents as required.
- POC environment availability.
- Approved user access.
- Data readiness.
- Optional connector prerequisites.
- Written authorisation for any live external target activity.

18. Exit Criteria and Decision Gates

18.1 Technical Exit Criteria

- All planned Must test cases are executed or explicitly recorded as Not Run with reason and decision impact.

- No unresolved S1 defect.
- All S2 defects either resolved or explicitly accepted as a condition by Bursa decision authority.
- Security/access/audit tests completed.
- POC data and export inventory reconciled.
- Production gap list completed with priority and owner.

18.2 Business Exit Criteria

- Bursa evaluators complete the success scorecard and usability feedback.
- Evidence is sufficient to explain both successful and unsuccessful criteria.
- No material benefit claim is based solely on synthetic timing or vendor assertion; where value is estimated, assumptions are documented.
- Executive stakeholders can review a consolidated outcome and drill down to supporting tests.

18.3 Decision Gate

Outcome	Meaning	Immediate next step
GO	POC meets agreed gates and production path is credible.	Start production discovery, architecture/security design and commercial/SOW process.
GO - CONDITIONS	Core value proven; specific gaps must be remediated or contractually/architecturally addressed.	Create condition closure plan and incorporate into production design/SOW.
TARGETED EXTENSION	Decision blocked by a small number of external dependencies or narrowly scoped untested criteria.	Time-box extension with fixed tests and no scope expansion.
NO-GO / RE-EVALUATE	Material functional, security, operational or evidence gap prevents justified progression.	Close POC; document lessons and alternative path.

19. POC Final Report Structure

The final report should be issued within five business days after the four-week evaluation window. It should be concise enough for executive review but preserve links/references to the detailed test evidence.

#	Section	Required content
1	Executive conclusion	Overall decision recommendation, key evidence, critical conditions.
2	Scope executed	What was and was not tested; deviations from baseline.
3	Environment and data	POC architecture, datasets, integrations, user roles, security controls.
4	Success scorecard	Final score for each criterion with gate status and evidence reference.
5	Test results	Pass/conditional/fail/not-run summary and detailed exception list.
6	Defects and limitations	S1-S4 defects, workarounds, product/config/data classification.
7	Evaluator feedback	Usability and operational observations from Bursa evaluators.
8	Value observations	Measured/observed workflow improvements and clearly labelled estimates.
9	Production gap assessment	Required integrations, data remediation, security review, operating model and scale testing.
10	Recommendation and next steps	GO / GO-CONDITIONS / EXTEND / NO-GO with actions, owners and target timing.
11	Data closeout	Data return/deletion confirmation, account closure and retained artefacts.

19.1 Executive One-Page Scorecard Template

Dimension	Result	Key evidence / condition
Functional fit	TBD	TBD
Cross-domain correlation	TBD	TBD
Security & auditability	TBD	TBD
Data & integration feasibility	TBD	TBD
Usability / operations	TBD	TBD
Reporting / executive visibility	TBD	TBD
Production readiness gaps	TBD	TBD
Overall decision	TBD	GO / GO-CONDITIONS / EXTEND / NO-GO

20. Appendices and References

Appendix A - Week 1 Success-Criteria Workshop Agenda

- Confirm business decision and stakeholders.
- Review scope and explicit exclusions.
- Confirm selected use cases and data set.
- Confirm each test case and benchmark.
- Assign Must / Should / Optional priorities.
- Confirm scoring thresholds and decision gate.

13. Confirm security/data handling and live-target authorisations.
14. Confirm evidence repository and acceptance process.
15. Freeze baseline and record unresolved prerequisites.

Appendix B - Evaluator Feedback Questions

Area	Question
Ease of use	Could you complete the assigned workflow without substantial assistance?
Traceability	Could you understand where a risk/finding/control result came from and what it was linked to?
Efficiency	Compared with the baseline process, did the workflow reduce manual searching/correlation?
Reporting	Were dashboard and exported results clear enough for your role?
Trust	Did the platform make evidence, calculations and AI-generated output sufficiently transparent for review?
Administration	Was configuration effort proportionate to the workflow value?
Adoption	Would you use this workflow in production if identified conditions were addressed?

Appendix C - Production Discovery Questions if POC Proceeds

- Target production deployment model and data residency.
- Identity, PAM and privileged administration model.
- Authoritative sources for assets, identities, vendors, controls, risks and evidence.
- Required SIEM, CMDB, ticketing, IdP, data lake and workflow integrations.
- Enterprise data volumes, retention, archival and backup requirements.
- HA, DR, RTO/RPO and performance requirements.
- Security assurance, vulnerability management, penetration testing and logging/SOC integration.
- Operating model: platform administration, content ownership, risk/control ownership and support.
- Migration strategy and reconciliation requirements.
- Regulatory, legal, privacy, outsourcing and third-party assurance requirements determined by Bursa.

Appendix D - Source Baseline

Internal product/commercial baseline used to prepare this draft:

- VoronDRQ Sales Kit README.md - Version 1.0, April 2026.
- VoronDRQ Proposal Templates - Template 5 POC Agreement, Version 1.0, April 2026.
- VoronDRQ Product Brochure v1.1 - August 2026.
- VoronDRQ Technical Proposal structure - platform architecture, deployment, security and integration sections.

Public Bursa Malaysia context referenced in this draft:

- Bursa Malaysia - Risk & Compliance Overview. [Bursa Malaysia website](#)
- Bursa Assist - "What are the key risks in the BTS3 implementation, and how will they be managed?" Updated 15 May 2026. [Bursa Assist article](#)

Reference discipline

Public sources are used only to establish evaluation context. Bursa's internal requirements, current state and control applicability must be confirmed directly by Bursa during POC discovery.

Appendix E - POC Agreement Alignment

This plan expands the sales-kit POC Agreement baseline into an execution-ready document. It preserves the baseline concept of a four-week POC, limited data/users, customer and vendor responsibilities, measurable success criteria, weekly checkpoints and a final report, while intentionally leaving commercial fees and contractual terms to a separate agreement.

Sales-kit POC baseline	How this document implements it
4-week POC from provisioning	Detailed Week 1-4 execution plan plus Week 5 reporting.
Limited tenant / sample data / named users	Defined scope, data envelope, access model and data worksheet.
Customer responsibilities	Expanded into prerequisites, data ownership, evaluator availability and RACI.
Voron responsibilities	Expanded into provisioning, configuration, data load, test support, defect triage and final report.
Success criteria	Weighted scorecard plus Must gates, test evidence and decision thresholds.
POC conclusion report	Defined final report structure, scorecard, production gap list and data closeout.

END OF DRAFT